

DANH MỤC TÀI LIỆU THAM KHẢO

Ghi theo định dạng **IEEE** như quy định. Chỉ bao gồm các tài liệu được trích dẫn, sử dụng và đề cập tới để bàn luận trong đồ án. Đánh số theo thứ tự từ điển của tên tác giả hoặc tổ chức.

Tiếng Anh

- [1] Baymard Institute, *Travel Accommodations 2024 Benchmark*, 2024. [Trực tuyến]. Có tại: <https://baymard.com/blog/travel-accommodations-2024-benchmark>
- [2] Google LLC, *Angular Documentation*, 2026. [Trực tuyến]. Có tại: <https://angular.dev>
- [3] Nginx Inc., *Module ngx_http_proxy_module*, 2026. [Trực tuyến]. Có tại: https://nginx.org/en/docs/http/ngx_http_proxy_module.html
- [4] M. Nottingham, E. Wilde và S. Dalal, *RFC 7807 — Problem Details for HTTP APIs*, Internet Engineering Task Force, 2016.
- [5] OWASP Foundation, *CSV Injection*, 2026. [Trực tuyến]. Có tại: https://owasp.org/www-community/attacks/CSV_Injection
- [6] OWASP Foundation, *OWASP Top Ten*, 2021. [Trực tuyến]. Có tại: <https://owasp.org/www-project-top-ten/>
- [7] PostgreSQL Global Development Group, *PostgreSQL 16 Documentation — GiST Indexes: Introduction*, 2026. [Trực tuyến]. Có tại: <https://www.postgresql.org/docs/16/gist-intro.html>
- [8] PostgreSQL Global Development Group, *PostgreSQL 16 Documentation — Range Types*, 2026. [Trực tuyến]. Có tại: <https://www.postgresql.org/docs/16/rangetypes.html>
- [9] PostgreSQL Global Development Group, *PostgreSQL 16 Documentation — Transaction Isolation*, 2026. [Trực tuyến]. Có tại: <https://www.postgresql.org/docs/16/transaction-iso.html>
- [10] Snappymob, *UI/UX Audit: Booking.com vs Agoda*, 2023. [Trực tuyến]. Có tại: <https://blog.snappymob.com/ui-ux-audit-booking-com-vs-agoda>

[11] VMware Inc., *Spring Boot Reference Documentation*, 2026. [Trực tuyến]. Có tại: <https://docs.spring.io/spring-boot/index.html>

[12] VMware Inc., *Spring Framework Reference — Rolling Back a Declarative Transaction*, 2026. [Trực tuyến]. Có tại: <https://docs.spring.io/spring-framework/reference/data-access/transaction/declarative/rolling-back.html>

[13] World Wide Web Consortium, *Web Content Accessibility Guidelines (WCAG) 2.1*, 2018. [Trực tuyến]. Có tại: <https://www.w3.org/TR/WCAG21/>

Tiếng Việt

[14] SePay, *Tài liệu tích hợp Webhooks*, 2026. [Trực tuyến]. Có tại: <https://docs.sepay.vn/tich-hop-webhooks.html>

PHỤ LỤC

Phụ lục A — Đặc tả mười một use case

Đặc tả đầy đủ của cả mười một use case, theo cùng một khuôn mẫu và sắp xếp theo số hiệu: tác nhân chính, mô tả, tiền điều kiện, hậu điều kiện, luồng sự kiện chính và các luồng thay thế kèm mã lỗi tương ứng.

UC1 — Tìm phòng trống

Mục	Nội dung
Mã	UC1
Tác nhân chính	Khách vãng lai, Khách có tài khoản
Mô tả	Khách tìm các loại phòng còn chỗ trong một khoảng ngày
Tiền điều kiện	Có ít nhất một loại phòng đang bật bán
Hậu điều kiện	Không có dữ liệu nào được ghi; đây là truy vấn chỉ đọc

Luồng sự kiện chính

1. Khách mở trang chủ; thanh tìm phòng nạp sẵn lịch của toàn homestay.
2. Khách chọn ngày nhận và ngày trả. Ngày quá khứ và ngày đã kín mọi loại phòng bị chặn ngay trong lịch, không cho chọn.
3. Khách chọn số người lớn, trẻ em, số phòng.
4. Hệ thống truy vấn và trả về các loại phòng còn chỗ, kèm tổng tiền cả kỳ và số phòng còn lại của từng loại.

Luồng thay thế

- *2a. Lịch không tải được:* khách vẫn chọn được ngày; mất phần chặn trước, tăng máy chủ vẫn từ chối ngày kín ở bước sau.
- *4a. Không loại phòng nào đủ chỗ:* hiện trạng thái rỗng kèm gợi ý đổi ngày hoặc giảm số khách mỗi phòng.

UC2 — Đặt phòng

Mục	Nội dung
Mã	UC2
Tác nhân chính	Khách vãng lai, Khách có tài khoản
Mô tả	Khách gửi yêu cầu đặt phòng cho một khoảng ngày và nhận mã đơn
Tiền điều kiện	Đã hoàn tất UC1 và chọn được một loại phòng còn chỗ

Mục	Nội dung
Hậu điều kiện	Đơn ở trạng thái PENDING_PAYMENT; các phòng vật lý đã được gán; hạn giữ chỗ 15 phút bắt đầu chạy

Luồng sự kiện chính

1. Khách nhập họ tên, số điện thoại, thư điện tử và ghi chú nếu có.
2. Khách nhập mã khuyến mãi tùy chọn; hệ thống kiểm tra và hiển thị ngay số tiền được giảm.
3. Khách xác nhận đơn.
4. Hệ thống mở một giao dịch, tính lại chi phí ở phía máy chủ, không tin số tiền do trình duyệt gửi lên.
5. Hệ thống chọn các phòng vật lý còn rảnh và ghi vào bảng gán phòng.
6. Cơ sở dữ liệu kiểm tra ràng buộc loại trừ. Nếu không vi phạm, giao dịch được commit.
7. Hệ thống sinh mã đơn, mã truy cập, thông tin thanh toán và trả về cho khách.
8. Hệ thống đưa thư xác nhận vào hàng đợi gửi.

Luồng thay thế và ngoại lệ

- 4a. Dữ liệu không hợp lệ (ngày trả không sau ngày nhận, số khách vượt sức chứa mỗi phòng) → trả lỗi INVALID_BOOKING_REQUEST mã 400, không ghi gì.
- 2a. Mã khuyến mãi không hợp lệ → INVALID_PROMOTION mã 400.
- 2b. Mã khuyến mãi hết lượt → PROMOTION_EXHAUSTED mã 409.
- 6a. Ràng buộc loại trừ bị vi phạm — một khách khác vừa đặt xong phòng đó trong tích tắc. Cơ sở dữ liệu trả SQLSTATE 23P01, giao dịch bị huỷ. Hệ thống mở **giao dịch mới** và thử phòng vật lý tiếp theo. Hết phòng để thử thì trả ROOM_NOT_AVAILABLE mã 409.
- 5a. Vượt giới hạn tần suất → TOO_MANY_REQUESTS mã 429.

UC3 — Thanh toán cọc

Mục	Nội dung
Mã	UC3
Tác nhân chính	Khách vãng lai, Khách có tài khoản
Mô tả	Khách chuyển khoản tiền cọc theo mã QR và hệ thống tự xác nhận
Tiền điều kiện	Đơn đang ở PENDING_PAYMENT và còn trong hạn giữ chỗ

Mục	Nội dung
Hậu điều kiện	Đơn chuyển sang CONFIRMED nếu đủ tiền

Luồng sự kiện chính

- Hệ thống hiển thị mã QR kèm thông tin chuyển khoản dạng chữ và đồng hồ đếm ngược tương ứng hạn giữ chỗ thật.
- Khách quét mã và chuyển khoản.
- Nhà cung cấp thanh toán phát hiện biến động số dư và gọi webhook.
- Hệ thống xác thực khoá, đối chiếu nội dung chuyển khoản với mã đơn và số tiền.
- Đủ tiền cọc, hệ thống chuyển đơn sang CONFIRMED và gửi thư xác nhận.
- Trình duyệt hỏi trạng thái định kỳ và tự chuyển sang trang hoàn tất.

Luồng thay thế

- 4a. Thiếu tiền → đơn sang AWAITING_REVIEW, đánh dấu cần đối soát.
- 4b. Thừa tiền → đánh dấu cần hoàn lại phần thừa.
- 4c. Webhook gửi lại lần hai → bỏ qua, không cộng tiền hai lần.
- 4d. Không khớp đơn nào → vẫn ghi vào nhật ký webhook cho người đối soát.
- 4e. Sai khoá xác thực → từ chối.
- 3a. Tiền về sau khi đơn đã hết hạn → mở lại đơn sang AWAITING_REVIEW, thử giành lại phòng; không giành được thì vào hàng đợi hoàn tiền.
- 2a. Hết hạn giữ chỗ mà không có tiền → bộ quét chuyển đơn sang EXPIRED và nhả phòng.

UC9 — Đặt ngày khả dụng của phòng

Mục	Nội dung
Mã	UC9
Tác nhân chính	Quản trị viên
Mô tả	Đóng một phòng vật lý trong một khoảng ngày; hệ thống tự mở lại khi hết khoảng
Tiền điều kiện	Đã đăng nhập vai trò ADMIN, đã đổi mật khẩu tạm
Hậu điều kiện	Phòng biến mất khỏi kết quả tìm phòng trong đúng khoảng ngày đó; không đơn nào bị huỷ

Luồng sự kiện chính

- Quản trị viên mở màn hình quản lý phòng và chọn một phòng vật lý.
- Hệ thống hiển thị các khoảng đóng còn hiệu lực của phòng đó.
- Quản trị viên chọn ngày bắt đầu đóng và ngày mở bán lại, nhập lý do.

- Hệ thống ghi khoảng đóng và cơ sở dữ liệu kiểm tra ràng buộc chống chồng lấn.
- Hệ thống trả về danh sách các đơn đang giao với khoảng vừa đóng, chỉ để cảnh báo.

Luồng thay thế

- 3a. Ngày mở bán lại không sau ngày bắt đầu → INVALID_ADMIN_REQUEST mã 400.
- 4a. Khoảng mới chồng lên một khoảng đã có → CLOSURE_OVERLAP mã 409.
- 5a. Không có đơn nào trong khoảng → không hiện cảnh báo.

Điểm thiết kế đáng lưu ý. Hệ thống cố ý **không chặn** việc đóng một phòng đang có đơn. Nếu chặn, chủ homestay không ghi nhận được sự thật rằng phòng hỏng từ ngày mai chỉ vì hệ thống còn một đơn cũ — trong khi sự thật đó vẫn xảy ra dù hệ thống có cho ghi hay không. Vai trò của hệ thống là **liệt kê** đúng các đơn bị ảnh hưởng để người quyết định nhìn thấy, không phải quyết định thay.

Hình A.1 thể hiện màn hình quản lý ngày khả dụng.

Hình A.1 — Màn hình quản lý ngày khả dụng (Nguồn: tác giả)

UC4 — Đối soát thanh toán

Mục	Nội dung
Mã	UC4

Mục	Nội dung
Tác nhân chính	Quản trị viên
Mô tả	Xử lý các khoản tiền không khớp tự động được
Tiền điều kiện	Đã đăng nhập vai trò ADMIN, đã đổi mật khẩu tạm
Hậu điều kiện	Khoản tiền chuyển sang trạng thái đã xử lý

Luồng sự kiện chính

1. Quản trị viên mở màn hình đối soát, thấy danh sách các khoản cần xử lý.
2. Chọn một khoản, xem chi tiết đơn và lịch sử thanh toán.
3. Quyết định: xác nhận thủ công, hoặc đánh dấu đã xử lý.
4. Hệ thống ghi lại quyết định và cập nhật trạng thái đối soát.

Luồng thay thế

- 3a. Khoản thừa tiền → đánh dấu cần hoàn tiền; **hệ thống không tự hoàn tiền**, việc chuyển khoản lại do người thực hiện bên ngoài.
- 3b. Khoản không khớp đơn nào → giữ trong nhật ký để tra cứu.

UC5 — Tra cứu và huỷ đơn

Mục	Nội dung
Mã	UC5
Tác nhân chính	Khách vắng lai, Khách có tài khoản
Mô tả	Khách tra cứu đơn và huỷ đơn mà không cần tài khoản
Tiền điều kiện	Khách có mã đơn và số điện thoại đã dùng khi đặt, hoặc có mã truy cập
Hậu điều kiện	Với thao tác huỷ: đơn sang CANCELLED, các phòng được nhả

Luồng sự kiện chính

1. Khách nhập mã đơn và số điện thoại.
2. Hệ thống xác thực và trả về thông tin đơn.
3. Khách chọn huỷ đơn.
4. Hệ thống chuyển trạng thái, nhả phòng và hoàn lượt khuyến mãi nếu có.

Luồng thay thế

- 2a. Mã đơn sai hoặc số điện thoại không khớp → trả về **cùng một thông báo lỗi** BOOKING_NOT_FOUND cho cả hai trường hợp, để không ai dò được mã đơn nào có thật.
- 3a. Trạng thái không cho phép huỷ → INVALID_STATE_TRANSITION mã 409.

- 1a. Vượt giới hạn tần suất tra cứu → TOO_MANY_REQUESTS mã 429.

UC6 — Quản lý đơn đặt phòng

Mục	Nội dung
Mã	UC6
Tác nhân chính	Quản trị viên
Mô tả	Theo dõi và chuyển trạng thái đơn theo máy trạng thái
Tiền điều kiện	Đã đăng nhập vai trò ADMIN
Hậu điều kiện	Trạng thái đơn thay đổi và một dòng lịch sử được ghi

Luồng sự kiện chính

1. Quản trị viên mở danh sách đơn, lọc theo trạng thái và khoảng ngày.
2. Mở chi tiết một đơn: thấy lịch sử trạng thái, các lần thanh toán, thư đã gửi và ghi chú nội bộ.
3. Chọn trạng thái mới trong số các trạng thái hợp lệ.
4. Hệ thống kiểm tra bước chuyển, ghi nhật ký, và thực hiện các việc kèm theo như nhà phòng hoặc hoàn lượt khuyến mãi.

Luồng thay thế

- 3a. Bước chuyển không hợp lệ → INVALID_STATE_TRANSITION mã 409.
- 4a. Chuyển sang `CHECKED\_OUT` → **không nhà phòng**, xem giải thích ở mục 3.3.2.

UC7 — Xem lại toàn bộ đơn đã đặt

Mục	Nội dung
Mã	UC7
Tác nhân chính	Khách có tài khoản
Mô tả	Khách đã đăng nhập xem lại toàn bộ đơn đã đặt ở một nơi
Tiền điều kiện	Đã đăng nhập với vai trò CUSTOMER
Hậu điều kiện	Không ghi dữ liệu; truy vấn chỉ đọc

Luồng sự kiện chính

1. Khách đăng nhập và mở trang danh sách đơn đã đặt.
2. Hệ thống trả về danh sách đơn có phân trang, mặc định 10 đơn mỗi trang.
3. Khách mở chi tiết một đơn bằng mã đơn.

Luồng thay thế

- 2a. Chưa có đơn nào → hiện trạng thái rỗng kèm liên kết tới trang đặt phòng.
- 3a. Mã đơn không thuộc về tài khoản đang đăng nhập → từ chối.

Điểm thiết kế đáng lưu ý. Danh sách đơn được lọc theo định danh lấy từ **token của phiên**, không theo tham số trên đường dẫn. Nếu lọc theo tham số, người dùng chỉ cần đổi số trên thanh địa chỉ là xem được đơn của người khác. Số phần tử mỗi trang cũng bị giới hạn trần ở phía máy chủ để một yêu cầu không kéo về toàn bộ bảng.

UC8 — Xem báo cáo doanh thu

Mục	Nội dung
Mã	UC8
Tác nhân chính	Quản trị viên
Mô tả	Xem tổng quan doanh thu, tỉ lệ lấp đầy và tỉ lệ huỷ theo tháng
Tiền điều kiện	Đã đăng nhập vai trò ADMIN
Hậu điều kiện	Không ghi dữ liệu

Luồng sự kiện chính

1. Quản trị viên mở trang tổng quan.
2. Hệ thống tính khoảng thời gian mặc định là một số tháng gần nhất tính tới đầu tháng sau.
3. Hệ thống truy vấn và trả về: giá trị đơn theo tháng, số tiền thực nhận theo tháng, tỉ lệ lấp đầy theo tháng, số đơn mới theo tháng, các loại phòng bán chạy nhất, tổng số đơn, số đơn huỷ, tỉ lệ huỷ, và số khoản chờ đối soát.
4. Quản trị viên xuất danh sách đơn ra tệp CSV nếu cần.

Luồng thay thế

- 2a. Quản trị viên chọn khoảng thời gian khác → hệ thống chuẩn hoá về đầu tháng rồi tính lại.
- 3a. Không có đơn nào trong kỳ → tỉ lệ huỷ trả về 0 thay vì gây lỗi chia cho không.

UC10 — Soạn nội dung trang chủ

Mục	Nội dung
Mã	UC10
Tác nhân chính	Quản trị viên
Mô tả	Cập nhật các khối nội dung trang chủ, biểu ngữ, thư viện ảnh và tin tức
Tiền điều kiện	Đã đăng nhập vai trò ADMIN
Hậu điều kiện	Nội dung đã lọc được lưu; trang công khai hiển

Mục	Nội dung
	thị nội dung mới

Luồng sự kiện chính

1. Quản trị viên mở một trong bốn màn hình quản lý nội dung.
2. Sửa nội dung, có thể nhập đoạn HTML cho phần thân.
3. Tải ảnh lên nếu cần.
4. Lưu. Hệ thống **lọc HTML ở tầng vào** theo danh sách thẻ cho phép tường minh trước khi ghi vào cơ sở dữ liệu.
5. Nội dung đã đăng xuất hiện trên trang công khai.

Luồng thay thế

- 4a. Nội dung chứa thẻ nguy hiểm → các thẻ đó bị gỡ bỏ, phần còn lại vẫn lưu.
- 3a. Tập tải lên sai định dạng hoặc vượt dung lượng → từ chối với mã lỗi tương ứng.
- 5a. Bài viết chưa đánh dấu đã đăng → không xuất hiện trên trang công khai.

UC11 — Viết đánh giá

Mục	Nội dung
Mã	UC11
Tác nhân chính	Khách đã trả phòng
Mô tả	Khách gửi đánh giá về kỳ lưu trú vừa qua
Tiền điều kiện	Đơn ở trạng thái CHECKED_OUT; khách có mã truy cập hoặc số điện thoại
Hậu điều kiện	Đánh giá được lưu ở trạng thái PENDING, chờ duyệt

Luồng sự kiện chính

1. Khách mở liên kết đánh giá và nhập điểm từ 1 tới 5, tiêu đề và nội dung.
2. Hệ thống xác thực khách qua mã truy cập hoặc số điện thoại.
3. Hệ thống kiểm tra đơn đã ở trạng thái CHECKED_OUT.
4. Hệ thống lưu đánh giá, **chụp tên khách từ đơn** chứ không nhận từ dữ liệu gửi lên, và đặt trạng thái chờ duyệt.
5. Quản trị viên duyệt, từ chối hoặc trả lời đánh giá.
6. Chỉ đánh giá đã duyệt mới hiển thị công khai.

Luồng thay thế

- 2a. Xác thực thất bại → BOOKING_NOT_FOUND.

- 3a. Đơn chưa trả phòng → từ chối kèm thông báo nêu rõ trạng thái hiện tại.
- 4a. Đơn đã có đánh giá → từ chối. Cột khoá đơn có ràng buộc duy nhất nên cơ sở dữ liệu vẫn là chốt chặn cuối cùng; việc kiểm ở tầng dịch vụ chỉ để trả về một thông báo dễ hiểu thay vì lỗi ràng buộc thô.

Điểm thiết kế đáng lưu ý. Nội dung đánh giá do khách nhập được lưu **nguyên văn** và hiển thị dưới dạng văn bản thuần, không lọc HTML. Lý do: khách không có nhu cầu định dạng, nên cách an toàn nhất là không diễn giải nội dung đó như mã đánh dấu.

Ảnh màn hình hỗ trợ cho phụ lục A

Hai màn hình dưới đây không nằm trong phần chữ của Chương 3 nhưng cần cho việc đối chiếu khi chấm: bước buộc đổi mật khẩu tạm ở lần đăng nhập quản trị đầu tiên, và trang chi tiết loại phòng mà khách thấy trước khi vào luồng đặt phòng.

Hình A.2 thể hiện bước buộc đổi mật khẩu tạm.

Đổi mật khẩu

Tài khoản này đang dùng mật khẩu tạm. Đổi mật khẩu để tiếp tục — mật khẩu tạm đã đi qua log và tin nhắn nên không còn là bí mật.

MẬT KHẨU HIỆN TẠI *

MẬT KHẨU MỚI *

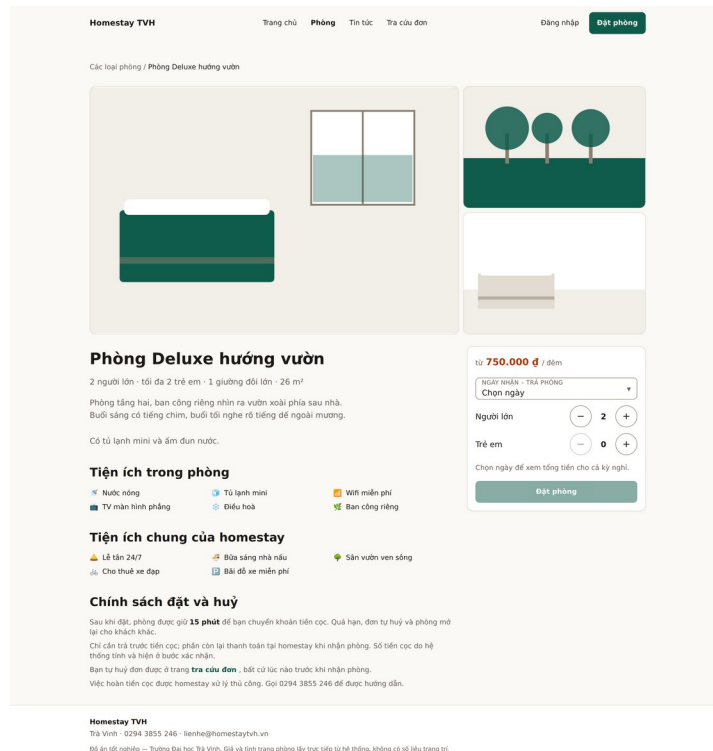
Ít nhất 8 ký tự.

NHẬP LẠI MẬT KHẨU MỚI *

Đổi mật khẩu và vào quản trị

Hình A.2 — Bước buộc đổi mật khẩu tạm (Nguồn: tác giả)

Hình A.3 thể hiện trang chi tiết một loại phòng.



Hình A.3 — Trang chi tiết một loại phòng (Nguồn: tác giả)

Phụ lục B — Mô tả hai mươi mốt bảng

Danh sách cột đầy đủ của cả hai mươi mốt bảng nghiệp vụ, theo cùng mẫu ba cột tên cột – kiểu – mô tả và ràng buộc. Bốn bảng cốt lõi xếp lên đầu vì mục 3.2.2 giải thích vì sao mỗi ràng buộc của chúng tồn tại; mười bảy bảng còn lại xếp theo thứ tự migration.

Bảng `refresh\_tokens` — phiên đăng nhập dài hạn

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
user_id	bigint	Khoá ngoại tới users, xoá theo tầng
token_hash	char(64)	uq_refresh_tokens_hash duy nhất. Lưu băm, không lưu token gốc
expires_at	timestamptz	Thời điểm hết hạn
revoked_at	timestamptz	Thời điểm thu hồi, rỗng khi còn hiệu lực
replaced_by	char(64)	Băm của token kế nhiệm sau khi xoay vòng
created_at	timestamptz	Thời điểm tạo

Cột replaced_by phục vụ phát hiện token bị đánh cắp: nếu một token đã bị thay thế lại được sử dụng, đó là dấu hiệu bất thường và cả chuỗi token bị thu hồi.

Nhóm cốt lõi — bốn bảng mang ràng buộc quyết định

Bảng `users` — tài khoản người dùng

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
email	varchar(255)	uq_users_email duy nhất; ck_users_email_lower buộc lưu chữ thường
password_hash	varchar(72)	Băm mật khẩu theo thuật toán bcrypt
full_name	varchar(150)	Họ tên, bắt buộc
phone	varchar(20)	Số điện thoại, có thể rỗng
role	varchar(20)	ck_users_role giới hạn hai giá trị CUSTOMER và ADMIN
enabled	boolean	Mặc định bật; tắt để khoá tài khoản
must_change_password	boolean	Cờ buộc đổi mật khẩu tạm ở lần đăng nhập đầu
token_version	integer	ck_users_token_version không âm. Tăng khi đăng xuất hoặc đổi mật khẩu để vô hiệu hoá token cũ ngay
created_at, updated_at	timestampz	Thời điểm tạo và cập nhật

Bảng `bookings` — đơn đặt phòng

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
code	varchar(20)	uq_bookings_code duy nhất. Mã đơn khách dùng để tra cứu
access_token	char(32)	uq_bookings_access_token duy nhất. Mã truy cập — bí mật thao tác, khác mã đơn
user_id	bigint	Khoá ngoại tới users, rỗng với khách vắng lại
guest_name	varchar(150)	Họ tên khách
guest_email	varchar(255)	Thư điện tử khách
guest_phone	varchar(20)	Số điện thoại khách
check_in, check_out	date	ck_bookings_dates buộc ngày trả sau ngày nhận
adults	integer	ck_bookings_adults tối thiểu 1
children	integer	ck_bookings_children không âm
room_type_id	bigint	Khoá ngoại tới room_types
room_type_name_snapshot	varchar(150)	Tên loại phòng chụp tại thời điểm đặt
unit_price_snapshot	numeric(12,2)	ck_bookings_unit_price lớn hơn 0. Giá chụp tại thời điểm đặt
room_quantity	integer	ck_bookings_room_qty tối

Tên cột	Kiểu	Mô tả và ràng buộc
		thiếu 1
subtotal_amount	numeric(12,2)	ck_bookings_subtotal không âm
discount_amount	numeric(12,2)	ck_bookings_discount không âm
total_amount	numeric(12,2)	ck_bookings_total không âm
deposit_amount	numeric(12,2)	ck_bookings_deposit không âm
promotion_id	bigint	Khoá ngoại fk_bookings_promotion thêm ở V5
status	varchar(20)	ck_bookings_status liệt kê tám trạng thái
payment_status	varchar(20)	ck_bookings_pay_status liệt kê bảy trạng thái thanh toán
special_request	text	Yêu cầu đặc biệt của khách
hold_expires_at	timestamptz	Hạn giữ chỗ
client_ip	inet	Địa chỉ mạng của người đặt
user_agent	varchar(255)	Thông tin trình duyệt
cancelled_at, cancel_reason	timestamptz, text	Thời điểm và lý do huỷ
created_at, updated_at	timestamptz	Thời điểm tạo và cập nhật

Bảng `booking\_rooms` — gán phòng vật lý cho đơn

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
booking_id	bigint	Khoá ngoại tới bookings, xoá theo tầng
room_id	bigint	Khoá ngoại tới rooms
check_in, check_out	date	ck_booking_rooms_dates buộc ngày trả sau ngày nhận
stay	daterange	Cột sinh tự động GENERATED ALWAYS AS (daterange(check_in, check_out, '[')) STORED
status	varchar(20)	ck_booking_rooms_status giới hạn ACTIVE và RELEASED

Bảng `room\_closures` — khoảng ngày phòng không nhận khách

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
room_id	bigint	Khoá ngoại tới rooms, xoá theo tầng
from_date	date	Đêm đầu tiên bị chặn
to_date	date	Ngày mở bán lại. ck_room_closures_dates buộc lớn hơn from_date
blocked	daterange	Cột sinh tự động theo quy ước nửa mở, cùng quy ước với

Tên cột	Kiểu	Mô tả và ràng buộc
		booking_rooms.stay
reason	varchar(300)	Lý do đóng phòng
created_by	bigint	Khoá ngoại tới users, đặt rỗng khi tài khoản bị xoá
created_at	timestampz	Thời điểm tạo

Nhóm V2 — Phòng và tiện nghi

Bảng `amenities` — tiện nghi

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
code	varchar(50)	uq_amenities_code duy nhất
name	varchar(100)	Tên hiển thị
icon	varchar(50)	Mã biểu tượng
category	varchar(20)	ck_amenities_category giới hạn ROOM và PROPERTY
display_order	integer	Thứ tự hiển thị

Bảng `room\_types` — loại phòng

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
code	varchar(50)	uq_room_types_code duy nhất
slug	varchar(120)	uq_room_types_slug duy nhất, dùng trong đường dẫn
name	varchar(150)	Tên loại phòng
short_description, description	text	Mô tả ngắn và mô tả đầy đủ
base_price	numeric(12,2)	ck_room_types_price phải lớn hơn 0
capacity_adults	integer	ck_room_types_adults tối thiểu 1
capacity_children	integer	ck_room_types_children không âm
bed_info	varchar(150)	Mô tả giường
area_sqm	numeric(6,2)	ck_room_types_area rỗng hoặc lớn hơn 0
display_order	integer	Thứ tự hiển thị
active	boolean	Tắt để ngừng bán loại phòng
created_at, updated_at	timestampz	Thời điểm tạo và cập nhật

Bảng `rooms` — phòng vật lý

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
room_type_id	bigint	Khoá ngoại tới room_types
room_number	varchar(20)	uq_rooms_number duy nhất
floor	integer	Tầng, có thể rỗng

Tên cột	Kiểu	Mô tả và ràng buộc
status	varchar(20)	ck_rooms_status giới hạn AVAILABLE, MAINTENANCE, OUT_OF_SERVICE
note	text	Ghi chú nội bộ
created_at, updated_at	timestampz	Thời điểm tạo và cập nhật

Đây là bảng mà ràng buộc chống trùng lịch đặt lên. Chỉ mục idx_rooms_type_status phục vụ truy vấn đếm phòng trống theo loại.

Bảng `room\_type\_images` — ảnh của loại phòng

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
room_type_id	bigint	Khoá ngoại, xoá theo tầng
url	varchar(500)	Đường dẫn ảnh
public_id	varchar(255)	Định danh trên dịch vụ lưu ảnh, rỗng khi lưu cục bộ
alt_text	varchar(255)	Văn bản thay thế phục vụ khả năng tiếp cận
display_order	integer	Thứ tự hiển thị
is_cover	boolean	Ảnh bìa. Chỉ mục duy nhất từng phân uq_room_type_images_cover bảo đảm mỗi loại phòng có tối đa một ảnh bìa

Bảng `room\_type\_amenities` — bảng nối loại phòng và tiện nghi

Tên cột	Kiểu	Mô tả và ràng buộc
room_type_id	bigint	Khoá ngoại, xoá theo tầng
amenity_id	bigint	Khoá ngoại, xoá theo tầng
		pk_room_type_amenities khoá chính tổ hợp hai cột

Đây là bảng duy nhất trong lược đồ **không có thực thể riêng** trong mã nguồn. Quan hệ nhiều–nhiều giữa loại phòng và tiện nghi được ánh xạ trực tiếp, nên tổng số thực thể là **20** trong khi tổng số bảng là **21**.

Nhóm V3 — Đặt phòng

Bảng `booking\_status\_history` — nhật ký chuyển trạng thái

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
booking_id	bigint	Khoá ngoại, xoá theo tầng
from_status	varchar(20)	ck_bsh_from_status rỗng hoặc thuộc tám trạng thái
to_status	varchar(20)	ck_bsh_to_status thuộc tám trạng thái

Tên cột	Kiểu	Mô tả và ràng buộc
changed_by	bigint	Khoá ngoại tới users, rỗng khi hệ thống tự chuyển
actor	varchar(20)	ck_bsh_actor giới hạn GUEST, CUSTOMER, ADMIN, SYSTEM
note	text	Ghi chú kèm theo lần chuyển
created_at	timestampz	Thời điểm chuyển

Nhóm V4 — Thanh toán và thư

Bảng `payments` — lần thanh toán

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
booking_id	bigint	Khoá ngoại, xoá theo tầng
attempt_no	integer	ck_payments_attempt tối thiểu 1. Cùng booking_id tạo thành chỉ mục duy nhất
provider	varchar(20)	ck_payments_provider giới hạn SEPAY và MANUAL
amount_expected	numeric(12,2)	ck_payments_expected lớn hơn 0
amount_received	numeric(12,2)	ck_payments_received không âm
qr_content, qr_image_url	text, varchar(500)	Nội dung và ảnh mã QR
transfer_content	varchar(50)	uq_payments_transfer_content duy nhất. Mã đơn ghép số thứ tự lần thử
status	varchar(20)	ck_payments_status liệt kê sáu trạng thái
reconcile_status	varchar(20)	ck_payments_reconcile giới hạn NONE, NEEDS_REVIEW, REFUND_REQUIRED, RESOLVED
provider_txn_id	varchar(100)	Mã giao dịch của nhà cung cấp
paid_at, expires_at	timestampz	Thời điểm thanh toán và hết hạn
created_at, updated_at	timestampz	Thời điểm tạo và cập nhật

Chỉ mục từng phần idx_payments_reconcile chỉ đánh chỉ mục các dòng cần đối soát, giúp màn hình đối soát truy vấn nhanh mà không phải quét toàn bảng.

Bảng `payment\_webhook\_events` — nhật ký webhook

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
provider	varchar(20)	Nhà cung cấp gửi webhook
external_id	varchar(100)	Mã sự kiện bên nhà cung cấp
payment_id	bigint	Khoá ngoại tới payments, rỗng khi không khớp đơn nào
payload	jsonb	Toàn bộ nội dung nhận được

Tên cột	Kiểu	Mô tả và ràng buộc
processing_result	varchar(20)	ck_pwe_result giới hạn MATCHED, UNMATCHED, LATE, DUPLICATE, ERROR
error_message	text	Thông báo lỗi nếu xử lý thất bại
received_at, processed_at	timestampz	Thời điểm nhận và xử lý

Chỉ mục duy nhất uq_webhook_provider_external trên cặp nhà cung cấp và mã sự kiện là cơ chế **chống cộng tiền hai lần** khi nhà cung cấp gửi lại webhook.

Bảng `outbound\_emails` — hàng đợi thư đi

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
booking_id	bigint	Khoá ngoại, đặt rỗng khi đơn bị xoá
template	varchar(100)	Tên mẫu thư
to_email	varchar(255)	Địa chỉ nhận
payload	jsonb	Dữ liệu điền vào mẫu
status	varchar(20)	ck_outbound_emails_status giới hạn PENDING, SENT, FAILED
attempts	integer	ck_outbound_emails_attempts không âm
last_error	text	Lỗi lần gửi gần nhất
sent_at, created_at	timestampz	Thời điểm gửi và tạo

Nhóm V5 — Khuyến mãi và đánh giá

Bảng `promotions` — mã khuyến mãi

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
code	varchar(50)	uq_promotions_code duy nhất
name, description	varchar(150), text	Tên và mô tả
discount_type	varchar(20)	ck_promotions_type giới hạn PERCENT và FIXED
discount_value	numeric(12,2)	ck_promotions_value lớn hơn 0
max_discount_amount	numeric(12,2)	ck_promotions_max rỗng hoặc lớn hơn 0
min_nights	integer	ck_promotions_nights tối thiểu 1
min_total_amount	numeric(12,2)	ck_promotions_min_total không âm
starts_at, ends_at	timestampz	ck_promotions_window buộc kết thúc sau bắt đầu
usage_limit	integer	Giới hạn lượt dùng, rỗng là không giới hạn

Tên cột	Kiểu	Mô tả và ràng buộc
used_count	integer	ck_promotions_used không âm; ck_promotions_usage buộc không vượt giới hạn
active	boolean	Tắt để ngừng áp dụng

Ràng buộc ck_promotions_usage bảo đảm số lượt đã dùng **không bao giờ vượt quá giới hạn** ngay ở tầng dữ liệu, kể cả khi nhiều đơn cùng áp một mã.

Bảng `reviews` — đánh giá của khách

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
booking_id	bigint	Khoá ngoại, xoá theo tầng. uq_reviews_booking duy nhất — mỗi đơn một đánh giá
user_id	bigint	Khoá ngoại tới users, rỗng với khách vắng lai
guest_name_snapshot	varchar(150)	Tên khách chụp từ đơn tại thời điểm đánh giá
rating	smallint	ck_reviews_rating trong khoảng 1 tới 5
title, content	varchar(200), text	Tiêu đề và nội dung
status	varchar(20)	ck_reviews_status giới hạn PENDING, APPROVED, REJECTED
admin_reply, replied_at	text, timestamptz	Phản hồi của quản trị viên
created_at	timestamptz	Thời điểm gửi

Nhóm V6 — Nội dung

Bảng `site\_contents` — khối nội dung trang chủ

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
section_key	varchar(100)	uq_site_contents_key duy nhất. Khoá định danh khối
title, subtitle	varchar(255)	Tiêu đề và tiêu đề phụ
body	text	Nội dung HTML đã lọc ở tầng vào
data	jsonb	Dữ liệu có cấu trúc tùy khối
image_url	varchar(500)	Ảnh minh hoạ
updated_by	bigint	Khoá ngoại tới users
updated_at	timestamptz	Thời điểm cập nhật

Bảng `banners` — biểu ngữ

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
title	varchar(255)	Tiêu đề, bắt buộc

Tên cột	Kiểu	Mô tả và ràng buộc
image_url	varchar(500)	Ảnh, bắt buộc
public_id	varchar(255)	Định danh trên dịch vụ lưu ảnh
link_url	varchar(500)	Đường dẫn khi nhấp vào
display_order	integer	Thứ tự hiển thị
active	boolean	Bật tắt hiển thị
starts_at, ends_at	timestampz	ck_banners_window buộc kết thúc sau bắt đầu khi cả hai cùng có giá trị

Bảng `gallery\_images` — thư viện ảnh

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
url	varchar(500)	Đường dẫn ảnh, bắt buộc
public_id	varchar(255)	Định danh trên dịch vụ lưu ảnh
caption	varchar(255)	Chú thích
category	varchar(50)	Phân nhóm ảnh
display_order	integer	Thứ tự hiển thị
active	boolean	Bật tắt hiển thị

Bảng `posts` — tin tức

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
slug	varchar(200)	uq_posts_slug duy nhất, dùng trong đường dẫn
title	varchar(255)	Tiêu đề, bắt buộc
excerpt, content	text	Trích dẫn ngắn và nội dung đầy đủ
cover_image_url	varchar(500)	Ảnh bìa
published	boolean	Cờ đã đăng
published_at	timestampz	Thời điểm đăng
author_id	bigint	Khoá ngoại tới users

Chỉ mục từng phần idx_posts_published chỉ đánh chỉ mục các bài đã đăng, phục vụ trang tin tức công khai.

Nhóm V7 — Ghi chú nội bộ

Bảng `booking\_notes` — ghi chú của quản trị viên trên đơn

Tên cột	Kiểu	Mô tả và ràng buộc
id	bigserial	Khoá chính
booking_id	bigint	Khoá ngoại, xoá theo tầng
author_id	bigint	Khoá ngoại tới users, đặt rỗng khi tài khoản bị xoá
content	text	ck_booking_notes_content buộc không rỗng sau khi cắt khoảng trắng

Tên cột	Kiểu	Mô tả và ràng buộc
created_at	timestampz	Thời điểm ghi

Bảng này tách khỏi `booking_status_history` vì mỗi dòng lịch sử bắt buộc kèm một lần chuyển trạng thái thật, mà máy trạng thái không cho phép chuyển từ một trạng thái sang chính nó. Ghi chú là dữ liệu **nội bộ** và không endpoint công khai nào đọc bảng này.

Nhóm V8 — Ngày khả dụng

PHỤ LỤC (TIẾP THEO)

Phụ lục C — Mã nguồn migration tạo ràng buộc chống trùng lịch

Trích từ tệp V3__bookings_and_exclusion.sql:

```
CREATE TABLE booking_rooms (  
    id          bigserial PRIMARY KEY,  
    booking_id bigint NOT NULL REFERENCES bookings (id) ON  
DELETE CASCADE,  
    room_id     bigint NOT NULL REFERENCES rooms (id),  
    check_in    date NOT NULL,  
    check_out   date NOT NULL,  
    stay        daterange GENERATED ALWAYS AS  
                        (daterange(check_in, check_out, '[]'))  
STORED,  
    status      varchar(20) NOT NULL DEFAULT 'ACTIVE',  
    CONSTRAINT ck_booking_rooms_dates CHECK (check_out > check_in),  
    CONSTRAINT ck_booking_rooms_status CHECK (status IN ('ACTIVE',  
'RELEASED'))  
);  
  
ALTER TABLE booking_rooms  
    ADD CONSTRAINT booking_rooms_no_overlap  
    EXCLUDE USING gist (room_id WITH =, stay WITH &&)  
    WHERE (status = 'ACTIVE');
```

Phụ lục D — Trigger ràng buộc hoãn

Trích từ cùng tệp migration:

```
CREATE FUNCTION assert_booking_room_count(p_booking_id bigint)  
RETURNS void AS $$  
BEGIN  
    IF EXISTS (  
        SELECT 1  
        FROM bookings b  
        WHERE b.id = p_booking_id  
            AND b.status NOT IN ('CANCELLED', 'EXPIRED', 'NO_SHOW')  
            AND b.room_quantity <> (  
                SELECT count(*)  
                FROM booking_rooms br  
                WHERE br.booking_id = b.id  
                    AND br.status = 'ACTIVE')  
    ) THEN  
        RAISE EXCEPTION 'booking_rooms không khớp room_quantity';  
    END IF;  
END;  
$$ LANGUAGE plpgsql;  
  
CREATE CONSTRAINT TRIGGER booking_room_count_check  
    AFTER INSERT OR UPDATE OR DELETE ON booking_rooms  
    DEFERRABLE INITIALLY DEFERRED  
    FOR EACH ROW EXECUTE FUNCTION check_booking_room_count();
```

Trigger được đặt ở **cả hai phía**: khi sửa bảng gán phòng, và khi sửa số lượng phòng trên đơn. Đặt một phía là để lọt trường hợp còn lại.

Phụ lục E — Bảng endpoint đầy đủ

Bảng đầy đủ 80 thao tác trên 63 đường dẫn được liệt kê trong tài liệu kỹ thuật docs/api.md của dự án, và xem được trực tiếp qua giao diện tài liệu tương tác của hệ thống đang chạy ở cấu hình trình diễn.

Cách đếm lại số thao tác từ hệ thống đang chạy:

```
curl -s localhost/v3/api-docs | python3 -c "
import json,sys
d = json.load(sys.stdin)
methods = ('get','post','put','delete','patch')
print(sum(len([m for m in v if m in methods]) for v in
d['paths'].values()))"
```

Phụ lục F — Migration bảng khoảng đóng phòng

Trích từ tệp V8__room_closures.sql:

```
CREATE TABLE room_closures (
  id          bigint PRIMARY KEY,
  room_id     bigint NOT NULL REFERENCES rooms (id) ON DELETE
CASCADE,
  from_date   date NOT NULL,
  to_date     date NOT NULL,
  blocked     daterange GENERATED ALWAYS AS
                (daterange(from_date, to_date, '[]'))
STORED,
  reason      varchar(300),
  created_by  bigint REFERENCES users (id) ON DELETE SET NULL,
  created_at  timestampz NOT NULL DEFAULT now(),
  CONSTRAINT ck_room_closures_dates CHECK (to_date > from_date)
);

ALTER TABLE room_closures
  ADD CONSTRAINT room_closures_no_overlap
  EXCLUDE USING gist (room_id WITH =, blocked WITH &&);

CREATE INDEX idx_room_closures_room ON room_closures (room_id,
from_date);
```

Phụ lục G — Cấu hình đóng gói

Tệp cấu hình đóng gói docker-compose.yml và cấu hình máy chủ web frontend/nginx.conf được lưu trong kho mã nguồn của dự án.

Điểm đáng lưu ý trong cấu hình máy chủ web là cú pháp tiền tố ưu tiên ở cả bốn khối chuyển tiếp:

```
location ^~ /api/           { ... }
location ^~ /swagger-ui/    { ... }
location ^~ /v3/api-docs/   { ... }
location ^~ /uploads/       { ... }
```

Phụ lục H — Lệnh kiểm chứng

Mục đích	Lệnh
Chạy toàn bộ kiểm thử	cd backend && ./mvnw verify
Biên dịch tầng giao diện	cd frontend && npm run build
Kiểm tra quy ước mã nguồn	cd frontend && npm run lint
Dựng và chạy toàn hệ thống	docker compose up -d --build
Kiểm tra trạng thái các dịch vụ	docker compose ps
Đếm số bảng trong lược đồ	SELECT count(*) FROM information_schema.tables WHERE table_schema = 'public' AND table_name <> 'flyway_schema_history';

Phụ lục I — Chi tiết 18 lớp kiểm thử

4.2.1. Bảng tổng hợp theo lớp

Lớp kiểm thử	Số ca	Chứng minh điều gì
SchemaMigrationTest	8	Migration dừng đúng 21 bảng ; mọi migration thành công; không migration nào bị sửa sau khi phát hành; cả hai cột kiểu khoảng đều là cột sinh tự động
SchemaConstraintIT	9	Từng ràng buộc kiểm tra thật sự chặn: thư điện tử không chữ thường, trạng thái sai chính tả, số tiền âm, ngày trả không sau ngày nhận, điểm đánh giá ngoài khoảng 1 tới 5
SqlStatesIT	2	Hai mã lỗi 23P01 và 25P02 được nhận diện đúng
`BookingConcurrencyIT`	3	Lớp quan trọng nhất. Nhiều luồng thật cùng đặt phòng cuối — đúng một luồng thắng; sau khi bắt lỗi ràng buộc, vòng thử tiếp theo phải ở giao dịch mới; đơn nhiều phòng gán được nhờ trigger hoãn
AvailabilityQueryIT	6	Đếm phòng trống đúng trong các tình huống dễ đếm sai: phòng bảo trì đang có đơn không bị trừ hai lần; loại phòng hết sạch biến mất khỏi kết quả; khoảng nửa mở cho khách trả và khách nhận cùng ngày; sức chứa so theo từng phòng; lịch trả đủ mọi ngày
BookingLifecycleIT	8	Bảng chuyển trạng thái: bước

Lớp kiểm thử	Số ca	Chứng minh điều gì
		hợp lệ đi được, bước không hợp lệ bị từ chối. CHECKED_OUT không nhả phòng
BookingExpiryIT	4	Bộ quét chuyển đơn quá hạn, nhả phòng, hoàn lượt khuyến mãi; đơn đã có tiền không bị quét
`RoomClosureIT`	9	Khoảng đóng phòng trừ đúng phòng, đúng đêm, ở cả bốn truy vấn; biên nửa mở; lịch không rơi mất ngày; khoảng chồng nhau bị từ chối; đóng phòng không huỷ đơn; khoảng đã qua rồi khỏi danh sách thao tác
SepayWebhookIT	10	Sai khoá xác thực bị từ chối; webhook gửi lại không cộng tiền hai lần; đủ tiền thì xác nhận; thiếu tiền thì chờ đối soát; thừa tiền thì đánh dấu hoàn; webhook không khớp đơn nào vẫn được ghi nhật ký
`PaymentRaceIT`	5	Cửa sổ tranh chấp giữa webhook và bộ quét hết hạn; nhánh giành lại phòng tồn trọng khoảng đóng phòng
AuthFlowIT	7	Đăng ký, đăng nhập, làm mới token, đăng xuất; số phiên bản token tăng làm token cũ mất hiệu lực ngay; token làm mới lưu dạng băm
`EndpointAuthorizationIT`	3	Mọi endpoint đã đăng ký nằm trong ma trận 30 tiền tố; cấm khai dòng bao trùm; endpoint không khai gì bị chặn
ContentSanitizerTest	17	Bộ lọc HTML gỡ thẻ kịch bản, chặn giao thức nguy hiểm trong liên kết, gỡ khung nhúng, gỡ ảnh ngoài danh sách nguồn cho phép, giữ thẻ hợp lệ
PublicContentIT	7	Giao diện công khai chỉ trả nội dung đã đăng; nội dung mặc định hiện ra khi chưa soạn; bài viết nháp không lộ
ReviewIT	8	Gửi đánh giá cần xác thực; tên khách chụp từ đơn, không nhận từ dữ liệu gửi lên; ràng buộc duy nhất chặn đánh giá thứ hai; chỉ đánh giá đã duyệt mới công khai
DashboardServiceIT	6	Doanh thu theo tháng, tỉ lệ lắp đây, tỉ lệ huỷ tính đúng trên dữ liệu thật
CsvExportTest	10	Xuất tệp CSV thoát đúng dấu

Lớp kiểm thử	Số ca	Chứng minh điều gì
		phẩy, dấu nhảy và ký tự xuống dòng trong dữ liệu
ImageUploadIT	7	Từ chối kiểu tệp sai; từ chối tệp vượt dung lượng; giải mã lại ảnh và đổi tên; chỉ quản trị viên tải lên được
Tổng	129	

Phụ lục J — Bảng đầy đủ mã lỗi

3.5.4. Thiết kế mã lỗi

Phản hồi lỗi theo chuẩn RFC 7807 [4] kèm trường code tự thêm. Tầng giao diện đọc trường code, **không** đọc câu chữ mô tả, nên việc sửa câu chữ ở tầng máy chủ không làm hỏng màn hình.

Mã lỗi	HTTP	Ý nghĩa
ROOM_NOT_AVAILABLE	409	Phòng vừa được đặt hết cho khoảng ngày này
INVALID_PROMOTION	400	Mã không hợp lệ hoặc chưa đủ điều kiện
PROMOTION_EXHAUSTED	409	Mã đã hết lượt
BOOKING_NOT_FOUND	404	Không có đơn khớp mã và số điện thoại
INVALID_ACCESS_TOKEN	403	Mã truy cập sai
INVALID_STATE_TRANSITION	409	Bước chuyển trạng thái không hợp lệ
INVALID_BOOKING_REQUEST	400	Dữ liệu đơn không hợp lệ
INVALID_ADMIN_REQUEST	400	Dữ liệu quản trị không hợp lệ
CLOSURE_OVERLAP	409	Khoảng đóng phòng chồng lên khoảng đã có
RESOURCE_IN_USE	409	Còn dữ liệu tham chiếu tới bản ghi cần xóa
PASSWORD_CHANGE_REQUIRED	403	Phải đổi mật khẩu tạm trước
UNSUPPORTED_IMAGE_TYPE	415	Định dạng ảnh không được chấp nhận
IMAGE_TOO_LARGE	413	Ảnh vượt giới hạn dung lượng
TOO_MANY_REQUESTS	429	Vượt giới hạn tần suất
UNAUTHORIZED	401	Thiếu hoặc sai token

Phụ lục K — Danh sách 32 yêu cầu chức năng

1.4.1. Yêu cầu chức năng

Nhóm A — Dành cho khách

Mã	Yêu cầu
CN-01	Xem danh sách loại phòng kèm tiện nghi, hình

Mã	Yêu cầu
	ảnh, giá
CN-02	Xem chi tiết một loại phòng, xem thư viện ảnh
CN-03	Tìm phòng trống theo khoảng ngày, số người lớn, trẻ em, số phòng
CN-04	Xem lịch từng đêm: đêm nào còn phòng, đêm nào hết
CN-05	Gửi yêu cầu đặt phòng, nhận mã đơn
CN-06	Xem chi phí dự kiến trước khi xác nhận đơn
CN-07	Áp dụng mã khuyến mãi và thấy ngay số tiền được giảm
CN-08	Thanh toán đặt cọc bằng mã QR
CN-09	Tra cứu đơn bằng mã đơn và số điện thoại
CN-10	Hủy đơn
CN-11	Nhận thư xác nhận qua thư điện tử
CN-12	Viết đánh giá sau khi trả phòng
CN-13	Đăng ký, đăng nhập, xem lại toàn bộ đơn đã đặt
CN-14	Đọc tin tức, xem thư viện ảnh của homestay

Nhóm B — Dành cho quản trị viên

Mã	Yêu cầu
CN-15	Đăng nhập khu quản trị; buộc đổi mật khẩu tạm ở lần đầu
CN-16	Xem danh sách đơn, lọc theo trạng thái và khoảng ngày
CN-17	Xem chi tiết đơn: lịch sử trạng thái, thanh toán, thư đã gửi, ghi chú
CN-18	Chuyển trạng thái đơn theo máy trạng thái hợp lệ
CN-19	Ghi chú nội bộ trên đơn
CN-20	Đối soát thanh toán: xác nhận thủ công, xử lý khoản lệch
CN-21	Quản lý loại phòng: thêm, sửa, xoá, gán tiện nghi, tải ảnh
CN-22	Quản lý phòng vật lý: thêm, sửa, đổi trạng thái vận hành
CN-23	Đóng phòng theo khoảng ngày — quản lý ngày khả dụng
CN-24	Quản lý mã khuyến mãi
CN-25	Duyệt, từ chối, trả lời đánh giá của khách
CN-26	Quản lý nội dung trang chủ, biểu ngữ, thư viện ảnh, tin tức
CN-27	Xem tổng quan: doanh thu, tỉ lệ lấp đầy, tỉ lệ hủy
CN-28	Xuất báo cáo đơn ra tệp định dạng CSV

Nhóm C — Hệ thống tự động

Mã	Yêu cầu
CN-29	Nhận webhook khi có tiền về, tự đối chiếu và xác nhận đơn

Mã	Yêu cầu
CN-30	Tự chuyển đơn quá hạn giữ chỗ sang trạng thái hết hạn và nhả phòng
CN-31	Gửi thư qua hàng đợi, ghi nhận mọi thư đã gửi
CN-32	Xử lý tiền về muộn: mở lại đơn, thử giành lại phòng

Phụ lục L — Bảng tổng hợp công nghệ

Tầng	Công nghệ	Phiên bản
Ngôn ngữ tầng máy chủ	Java	21 (LTS)
Nền tảng tầng máy chủ	Spring Boot	3.5.6
Truy cập dữ liệu	Spring Data JPA / Hibernate, Spring JDBC	theo nền tảng
Bảo mật	Spring Security và JWT	theo nền tảng
Cơ sở dữ liệu	PostgreSQL	16
Quản lý lược đồ	Flyway	theo nền tảng
Giới hạn tần suất	bucket4j	—
Lọc HTML	OWASP java-html-sanitizer	20240325.1
Kiểm thử	JUnit 5, AssertJ, Testcontainers	—
Ngôn ngữ tầng giao diện	TypeScript	theo Angular
Nền tảng tầng giao diện	Angular	21
Định kiểu	Tailwind CSS	4
Máy chủ web	nginx	alpine
Đóng gói	Docker, Docker Compose	Engine 24+, Compose v2
Thư trong môi trường trình diễn	Mailpit	—
Thanh toán	SePay và VietQR	—

Phụ lục M — Chi tiết kiểm thử bảo mật

Kịch bản tấn công	Kết quả
Giả mạo tiêu đề địa chỉ để vượt giới hạn tần suất	Thất bại — vẫn bị chặn ở đúng ngưỡng
Gọi endpoint quản trị không có token	Từ chối, mã 401
Gọi endpoint quản trị bằng token vai trò khách	Từ chối, mã 403
Dùng token cũ sau khi đã đổi mật khẩu	Từ chối, mã 401 — token cũ mất hiệu lực ngay
Gọi webhook không có khoá xác thực	Từ chối
Gửi lại cùng một webhook lần hai	Bỏ qua, không cộng tiền hai lần
Chèn thẻ kịch bản vào nội dung quản lý	Bị bộ lọc gỡ bỏ
Xem trạng thái thanh toán chỉ bằng mã đơn	Từ chối — bắt buộc mã truy cập
Truy cập đơn của người khác qua tham số đường dẫn	Từ chối — lọc theo token của phiên

Phụ lục N — Danh sách kiểm thử thủ công

Danh sách tối thiểu cần chạy trên bản đóng gói:

1. Trang chủ có nội dung thật: 4 loại phòng, thư viện ảnh, đánh giá, tin tức.
2. Đặt một đơn từ đầu đến khi ra mã QR.

3. Tải lại trang ở màn hình thanh toán — vẫn thấy mã QR và đồng hồ đếm ngược.
4. Tra cứu đơn bằng mã và số điện thoại; thử sai số điện thoại thì bị từ chối.
5. Huỷ đơn; kiểm tra phòng mở lại bằng cách đặt lại đúng ngày đó.
6. Đăng nhập quản trị, bị buộc đổi mật khẩu, rồi vào trang tổng quan.
7. Màn hình đối soát có sẵn khoản cần xử lý.
8. Sửa một khối nội dung trang chủ rồi mở lại trang chủ để thấy thay đổi.
9. Mở hộp thư giả lập xem thư xác nhận đã gửi.
10. Đóng một phòng vài ngày; tìm phòng đúng khoảng đó thấy số phòng giảm đúng một, và đêm mở bán lại **không** giảm.

Phụ lục O — Mười hai yêu cầu phi chức năng

Bảng đầy đủ của mục 1.4.2. Cột cuối là cách kiểm chứng, không phải lời hứa.

Mã	Loại	Yêu cầu	Cách kiểm chứng
PCN-01	Toàn vẹn	Không bao giờ bán trùng một phòng, kể cả khi có tranh chấp	Kiểm thử đa luồng thật
PCN-02	Toàn vẹn	Số phòng đã gán luôn khớp số phòng đơn yêu cầu	Trigger hoàn ở cơ sở dữ liệu
PCN-03	Toàn vẹn	Không nhánh nào để tiền biến mất im lặng	Kiểm thử cửa sổ tranh chấp webhook
PCN-04	Bảo mật	Mặc định từ chối mọi endpoint chưa khai quyền	Kiểm thử ma trận 30 tiền tố
PCN-05	Bảo mật	Chống dò mật khẩu và spam đặt phòng	Giới hạn tần suất theo 9 khoá
PCN-06	Bảo mật	Không có bí mật nào nằm trong mã nguồn	Ứng dụng dừng khởi động khi thiếu biến
PCN-07	Khả dụng	Giao diện sử dụng được trên điện thoại	Kiểm ở 3 độ rộng màn hình
PCN-08	Khả dụng	Đạt chuẩn WCAG 2.1 mức A và AA [13]	Quét tự động
PCN-09	Khả dụng	Mọi vùng chạm tối thiểu 44×44 điểm ảnh	Đo tự động
PCN-10	Hiệu năng	Lịch cả kỳ lấy trong một truy vấn, không lặp từng đêm	Đọc mã truy vấn
PCN-11	Triển khai	Ba lệnh từ lúc sao chép mã nguồn tới lúc chạy	Thực nghiệm
PCN-12	Bảo trì	Lược đồ do công cụ migration quản lý, migration bất biến	Kiểm thử checksum

Phụ lục P — Cây gói tầng máy chủ

Cây gói đầy đủ của mục 3.4.2.

com.tvh.homestay	
— auth/	— đăng nhập, token, phiên làm việc
— user/	— người dùng
— room/	— loại phòng, phòng, tiện nghi, khoảng đóng
— availability/	— truy vấn phòng trống
— booking/	— đơn, máy trạng thái, gán phòng, tính giá
— payment/	— webhook, đối soát
— promotion/	— mã khuyến mãi
— review/	— đánh giá
— cms/	— thực thể nội dung trang chủ
— content/	— điều khiển nội dung công khai và quản trị
— admin/	— điều khiển và dịch vụ khu quản trị
— report/	— tổng quan, xuất tệp CSV
— storage/	— tải ảnh lên
— mail/	— hàng đợi thư
— common/	— xử lý ngoại lệ, tiện ích dùng chung
— demo/	— nạp dữ liệu mẫu, chỉ hoạt động ở cấu hình trình diễn

Phụ lục Q — Chín khoá giới hạn tần suất

Hạn mức đầy đủ của mục 3.5.3.

Khoá	Hạn mức	Áp dụng cho
ip:auth	10 lần mỗi phút	Mọi endpoint xác thực
email:login	5 lần mỗi phút	Đăng nhập, theo thư điện tử trong thân yêu cầu
ip:availability	60 lần mỗi phút	Truy vấn phòng trống
ip:promo	20 lần mỗi phút	Kiểm tra mã khuyến mãi
ip:booking-create	10 lần mỗi phút	Tạo đơn
phone:booking	10 lần mỗi giờ	Tạo đơn, theo số điện thoại
ip:lookup	10 lần mỗi phút	Tra cứu đơn
code:lookup	5 lần mỗi giờ	Tra cứu đơn, theo mã đơn
ip:cancel	10 lần mỗi phút	Hủy đơn